

The Personal Data Privacy and Security Act of 2009 (S. 1490 Official title: A bill to prevent and mitigate identity theft, to ensure privacy, to provide notice of security breaches, and to enhance criminal penalties, law enforcement assistance, and other protections against security breaches, fraudulent access, and misuse of personally identifiable information), was a bill proposed in the United States Congress to increase protection of personally identifiable information by private companies and government agencies, set guidelines and restrictions on personal data sharing by data brokers, and to enhance criminal penalty for identity theft and other violations of data privacy and security.

The bill was sponsored in the United States Senate by Patrick Leahy (Democrat-Vermont), where it is known as S.1490.

Status

Senator Patrick Leahy introduced the bill on July 22, 2009 and was referred to the Senate Judiciary Committee where it was approved. The last action was on December 17, 2009.

This bill did not come up for debate during the 111th United States Congress and at the end of the 2009-2010 session and never became law.

Summary

The Congressional Research Service (CRS) of the Library of Congress summarizes the bill in its four main parts.

Title I - Enhancing Punishment for Identity Theft and Other Violations of Data Privacy and Security

Section 101

Amends the federal criminal code to add intentionally accessing a computer without authorization to the definition of racketeering activity.

Section 102

Imposes a fine and/or prison term of up to five years for intentionally and willfully concealing a security breach involving sensitive personally identifiable information that causes economic damage to one or more persons. It defines "sensitive personally identifiable information" to include an individual's name in combination with other personal information, such as a social security number, home address, date of birth, biometrics data, or financial account information.

Section 103

This directs the U.S. Sentencing Commission to review and amend, if appropriate, federal sentencing guidelines for persons convicted of using fraud to access, or to misuse, digitized or electronic personally identifiable information, including sentencing guidelines for identity theft.

Section 104

Amends the federal bankruptcy code to prohibit the dismissal or conversion of a bankruptcy case based upon a debtor's failure to meet means testing eligibility requirements if such debtor is a victim of identity theft.

Title II - Data Brokers

Section 201

Requires interstate data brokers (defined as business entities which, for monetary fees or dues, regularly engage in the practice of collecting, transmitting, or providing access to sensitive personally identifiable information on more than 5,000 individuals to nonaffiliated third parties on an interstate basis) to: (1) disclose to a requesting individual all personal

electronic records pertaining to such individual in their databases or systems at the time of such request; (2) provide guidance to such individuals for correcting inaccuracies in their records; (3) provide written or electronic notice of any adverse action taken against an individual by a third party based upon information in their databases; and (4) correct any inaccurate information in their databases. Sets forth procedures for disputing the completeness or accuracy of information in a data broker's database. Permits a data broker to decline to investigate or terminate a review of information disputed by an individual if the data broker reasonably determines that the dispute is frivolous and intended to perpetrate fraud.

Section 202

Imposes civil penalties on data brokers who violate the requirements of this title. Grants the Federal Trade Commission (FTC) enforcement authority over data brokers. Allows state attorneys general to pursue civil remedies against data brokers who are deemed to pose a threat to state residents.

Section 203

Preempts state regulation of data brokers.

Section 204

Makes the provisions of this title effective 180 days after enactment of this Act.

Title III - Privacy and Security of Personally Identifiable Information

Subtitle A - A Data Privacy and Security Program

Section 301

Imposes requirements for a personal data privacy and security program on business entities

that maintain sensitive personally identifiable information in electronic or digital form on 10,000 or more U.S. persons. Exempts certain financial institutions, covered entities under the Health Insurance Portability and Accountability Act (HIPAA), and public records from such requirements.

Section 302

Requires a business entity that is subject to data privacy and security requirements to: (1) implement a comprehensive personal data privacy and security program to ensure the privacy, security, and confidentiality of sensitive personally identifying information and to protect against breaches of and unauthorized access to such information that could create a significant risk of harm or fraud to any individual; (2) conduct risk assessments of potential security breaches; (3) adopt risk management and control policies and procedures; (4) ensure employee training and supervision for implementation of data security programs; and (5) undertake vulnerability testing and monitoring of personal data privacy and security programs.

Section 303

Imposes civil penalties on business entities that violate the data privacy and security requirements of this subtitle. Grants enforcement authority for such requirements to the FTC.

Section 304

Preempts state laws relating to administrative, technical, and physical safeguards for the protection of sensitive personally identifying information.

Subtitle B - Security Breach Notification

Section 311

Requires any agency or business entity with sensitive personally identifiable information to notify without unreasonable delay any U.S. resident of a security breach in which such resident's information has been, or is reasonably believed to have been, accessed or acquired.

Section 312

Exempts agencies or business entities from security breach notification requirements if they provide written certification to the Secret Service that providing such notification would impede a criminal investigation or damage national security. Requires the Secret Service to evaluate the merits of such certifications.

Section 313

Requires an agency or business entity to give notice of a security breach to any affected individuals: (1) by written notice to their last known home mailing address, by telephone, or by email (if email notification was consented to); and (2) to major media outlets if the number of residents in a state affected by a security breach exceeds 5,000.

Section 314

Requires the notification to individuals whose sensitive personally identifiable information has been accessed to include: (1) a description of the categories of information an unauthorized individual has acquired; and (2) toll-free numbers for contacting the agency or business entity whose databases have been breached and major credit reporting agencies.

Section 315

Requires any business entity or agency that is required to provide notification to more than 5,000 individuals of a security breach to notify all consumer reporting agencies.

Section 316

Requires any business entity or agency to notify the Secret Service of security breaches of sensitive personally identifying information within 14 days of any data security breach that involves: (1) more than 10,000 individuals; (2) a database that contains information about more than one million individuals nationwide; (3) a federal government database; or (4) individuals known to be government employees or contractors involved in national security or law enforcement. Requires the Secret Service to notify the Federal Bureau of Investigation (FBI), the U.S. Postal Service, and the attorney general of each affected state of a security breach within 14 days of receiving notice of any breach.

Section 317

Authorizes the Attorney General to bring a civil action, including an injunction, in a U.S. district court for violations of security breach notification requirements.

Section 318

Allows state attorneys general to bring a civil action in a U.S. district court to enforce security breach notification requirements. Authorizes the Attorney General to stay, or intervene in, any state action.

Section 319

Declares that the provisions of this subtitle shall supersede any other provision of federal or state law relating to notification by an interstate business entity or agency of a security breach.

Section 320

Authorizes appropriations to the Secret Service to carry out investigations and risk

assessments of security breaches.

Section 321

Requires the Secret Service to report to Congress on security breaches resulting from risk assessment exemptions.

Section 322

Makes the provisions of this subtitle effective 90 days after enactment of this Act.

Title IV - Government Access to And Use of Commercial Data

Section 401

Requires the Administrator of the General Services Administration (GSA), in awarding contracts totaling more than \$500,000 to data brokers, to evaluate their data privacy and security programs, their compliance, the extent to which their databases and systems have been compromised by security.

Support and opposition

Support

Support from cyber industry media when the bill was first introduced regarded the bill for its comprehensive approach to data security and personally identifiable information and the provisions for accountability in security breaches. The comprehensive nature of the bill was intended to patch together different laws from the state level that protect some residents into a federal bill that would have supremacy and offer greater protection to individuals' information, most notably preempting State data breach notification laws. Consumers Union, the non-profit publisher of Consumer Reports, addressed Senator Leahy directly to offer support. Unfortunately for proponents of the bill, the bill did not receive the expected

attention in Congress.

Opposition

Organizations in opposition

U.S. Chamber of Commerce

American Association of Advertising Agencies

American Financial Services Association

Internet Commerce Coalition

National Automobile Dealers Association

National Retail Federation

Retail Industry Leaders Association

National Business Coalition on E-Commerce and Privacy

The Financial Services Roundtable

Consumer Data Industry Association

== References ==